

Plan 3 — Integration Data Scope (US + EU)

Status: Locked 2026-04-24 **Companion docs:** plan-1-auth.md, plan-2-retention.md, plan-4-integration-tech.md, plan-5-llm-cost.md, Skillnex_Privacy_Compliance_Engineering_Guide.pdf

Executive summary

Skillnex pulls only the data necessary to compute competency scores from each connected system. Every integration ships with a three-tier scope: `default_pull` (granted automatically on OAuth), `opt_in_pull` (toggled per-tenant on the consent screen for high-value but riskier fields), and `never_pull` (hardcoded, no override possible — covers special-category data, message bodies, customer-of-customer data). The same allowlist that gates fetches is rendered in the consent screen, copied into the DPA, auto-populates the public sub-processor list, and tested in CI. Slack DM contents and HRIS Article-9 fields are hard limits with no toggle. Per-employee opt-out is one-click in `/app/my-review`. EU customers get Standard Contractual Clauses for any US-bound data flow during the pilot; full EU region opens when the second EU customer signs.

Locked decisions

#	Decision
1	OAuth re-consent on scope expansion: prompt customer to re-authorize
2	Three-tier scope model — <code>default_pull</code> / <code>opt_in_pull</code> / <code>never_pull</code>
3	Salesforce custom fields: ignore by default , customer can request whitelist via support
4	HRIS performance review comments: never via integration , only via explicit per-cycle upload
5	Per-employee opt-out: one-click in <code>/app/my-review</code>
6	Aggregate retention: purge at 90 days unless frozen into a locked review
7	Terminated employees: flag as terminated, keep until tenant retention expires
8	Sub-processor list: public at <code>/security/subprocessors</code>
9	Integration data encryption: same key as employees table ; per-integration KMS is Year-1
10	Customer-narrowable scope: yes, post-pilot via per-tenant overrides

Legal framework

Rule	What it requires for integration data
GDPR Art. 5(1)(c) Data minimization	Pull only what's necessary to compute the score. Every pulled field traces to a competency.
GDPR Art. 6 Lawful basis	"Performance of contract" + "legitimate interest" — customer collects, we process.
GDPR Art. 9 Special-category	Health, race, religion, sexual orientation, political, union, biometrics → prohibited. We refuse.
GDPR Art. 28 Processor obligations	DPA names every sub-processor. Each new integration = new sub-processor = customer notice.
GDPR Art. 44-49 International transfers	EU customer data → US infra requires SCCs or adequacy decision.
CCPA §1798.140(d) B2B exemption	Largely exempt for employee data. We still owe notice + right-to-delete.
CCPA §1798.105 Right to delete	45-day window; we commit to 7.
State Bar Model Rule 1.6	Law firm clients: never ingest client matter information, client names, privileged communications.
Source-system TOS	Each platform has its own API terms. We respect platform-specific restrictions (e.g., Slack content restrictions).

Three-tier scope model

```

`ts // lib/integrations/scope.ts export const INTEGRATION_SCOPE = {
[integration_id]: { default_pull: [...], // pulled automatically once OAuth
granted opt_in_pull: [ // shown as togglable on the consent screen { field: "...",
risk: "...", value: "...", }, ], never_pull: [...], // hardcoded, no toggle, no
exception sub_processor: "...", eu_residency: "...", sccs_required_for_eu: bool,
competencies_supported: [...], }, } as const; `

```

Per-integration allowlist — master table

Integration	DEFAULT_PULL	OPT/NPULL	NEVER_PULL
BambooHR / HRIS	<i>employeeid</i> , <i>fullname</i> , <i>workemail</i> , <i>hiredate</i> , <i>terminationdate</i> , <i>managerid</i> , <i>department</i> , <i>jobtitle</i> , <i>employmenttype</i> , <i>annualbasesalary</i> , <i>location</i> , <i>level</i>	level/grade descriptions, custom field labels (with content review)	DOB, SSN, address, ADA accommodations, FMLA, medical, race, ethnicity, religion, political, union, sexual orientation, dependents, marital status

Integration	DEFAULT_PULL	OPT/MPULL	NEVER_PULL
Salesforce	<i>ownerid, opportunityamount, opportunitystage, opportunitycloseddate, activitycountperuser</i> (calls /emails/meetings/tasks)	quarter-end opportunity dates by name-hash (for trend), <i>leadsourcetype</i>	<i>accountname, contactname, opportunityname, opportunitydescription, accountaddress, casedescriptions, accountindustry, accountrevenue, account_notes</i>
GitHub	PR author, PR mergedat, <i>PR reviewcount</i> , PR reviewturnaroundhours, <i>commitcountperauthor, code reviewcommentscount, issuecommentscount</i>	branch naming patterns (for trunk-based-dev signal)	PR titles, PR body, commit messages, code diffs, issue body, comment bodies, file paths, repo names of private repos
Jira	<i>ticketid, assigneeid, status, statuschangedat, storypoints, priority, ticketcreatedat, ticketresolvedat, timeinstatusbreakdowns</i>	story-point text labels (for "complex" classification)	ticket title, ticket description, comment bodies, attachment filenames, attachment contents, custom-field text, watcher lists
Slack	<i>messagecountperuserper channelperday, reactioncountreceived, mentioncountreceived, responsetimetothreadreplies (median), channelmembershipcount, activechannels_count</i>	channel names (for "active in #engineering" signal)	<i>messagetext, threadtext</i> , DM contents (always), shared files, file contents, channel topics, channel descriptions, voice/video transcripts, screenshots
Microsoft Teams	same as Slack	same as Slack	same as Slack
Calendar (Google/M365)	<i>meetingcountperuserperday, totalmeetingminutesperuserperday, meetingattendeecountaggregated, crossteammeetingcount, 1:1meetingcount, focustimeblockscount</i>	meeting titles, attendee email domains	recordings, attached documents, meeting descriptions, <i>attendeeemailaddressesoutsidecompany, recurringmeetingpatterns</i> withexternal_parties
LMS (Workday Learning / Coursera Business / Udemy)	<i>courseid, completionstatus, hourslogged, certificationid, certificationearnedat</i>	course names mapped to categories (customer-side mapping)	course descriptions if they reveal protected info
Lattice / 15Five / Culture Amp	<i>existingoverallratingspercycle, existingcompetencyratingspercycle, reviewcycledates, manageridat_time</i>	nothing (review prose stays upload-only)	<i>reviewtextcontent, peerreviewtext, 1:1meetingnotes, OKRprogressnotes</i> withtext

Integration	Mechanism	Frequency
Salesforce	Platform Events (webhooks)	Real-time
GitHub	Webhooks (org-level)	Real-time
Jira	Webhooks	Real-time
Slack	Events API	Real-time
Calendar	Daily batch (no useful webhooks)	Daily 02:00 tenant-local
BambooHR	Daily batch + on-demand at cycle close	Daily
Workday	Daily batch (their EIB scheduling)	Daily
LMS	Weekly batch	Weekly
Lattice / 15Five	At cycle close	Per cycle
Time tracking	Daily batch	Daily

Cache policy per integration

Integration	Aggregates retention	Raw events retention
BambooHR	90 days	0 (re-pull each cycle)
Salesforce	90 days	30 days
GitHub	90 days	7 days
Jira	90 days	7 days
Slack	90 days	24 hours
Calendar	90 days	30 days (event_id list for audit)
LMS	90 days	n/a
Lattice / 15Five	Tenant lifetime (frozen at cycle close)	n/a
Time tracking	90 days	7 days
Scribe / Notion	90 days	7 days

Aggregates frozen into a locked review survive the 90-day rolloff (audit-trail necessity).

Sub-processor list — public

URL: </security/subprocessors>. Auto-generated from `INTEGRATION_SCOPE`. Customers notified 30 days before any new sub-processor is added.

``` Skillnex Sub-Processors (current as of YYYY-MM-DD)

Always active:

- Anthropic, PBC — LLM API for narrative generation
- DigitalOcean LLC — Application hosting + storage
- Resend Inc. — Transactional email delivery

Activated when customer connects:

- Salesforce.com Inc. — CRM integration
- GitHub Inc. — Code activity integration
- Atlassian Pty Ltd — Jira integration
- Slack Technologies LLC — Workplace communication metadata
- Google LLC — Calendar integration
- Microsoft Corporation — Teams + Outlook + Microsoft 365
- BambooHR LLC — HRIS integration

...

Notification flow on add: in-app banner + email to all Owner-role users 30 days before activation. Customer may object; if so, that integration isn't available to them.

## EU data flows

When an EU tenant connects a US-headquartered integration (Salesforce, GitHub, Slack):

- Each platform handles its own EU-US transfer compliance via their SCCs or adequacy decision
- Skillnex DPA includes EU SCCs for any data flowing to US-hosted Skillnex infrastructure during the pilot
- When EU region opens (post-pilot, second EU customer signs), this stops being a transfer issue — EU customer data lives in EU infrastructure

## State Bar / law firm pilot — scope statement

Sent before pilot start, satisfies 80% of ABA Model Rule 1.6 concerns:

*"Skillnex processes employee performance data only. We never ingest client matter information, client names, privileged communications, work product, or any data subject to attorney-client privilege. Our integration scope is limited to employee activity metadata: counts of opportunities and tickets owned, time-to-respond patterns, certification hours, and similar non-content metrics. We do not pull opportunity names, ticket titles, message bodies, document contents, or meeting subjects from any source system. Our scope is enforced in code (`INTEGRATION_SCOPE` allowlist) and cannot be expanded without an updated DPA."*

Backed by the per-integration `never_pull` lists.

## Build sequence (3 days)

| Day | Work                                                                                                                                                                  |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1   | Create <code>lib/integrations/scope.ts</code> with full allowlist for all 10 integrations                                                                             |
| 1   | Add <code>integration_opt_out</code> flag to <code>employees</code> ; add <code>/app/my-review</code> opt-out toggle                                                  |
| 2   | Build per-integration consent screen template (used by all OAuth flows in Plan 4)                                                                                     |
| 2   | Auto-generate sub-processor list from <code>INTEGRATION_SCOPE</code> to <code>/security/subprocessors</code>                                                          |
| 3   | DPA template gets per-integration scope tables auto-inserted                                                                                                          |
| 3   | Tests: every integration's <code>default_pull/opt_in_pull/never_pull</code> lists have no overlap, every supported competency is real, every sub-processor has a name |
| 3   | State Bar scope statement drafted to <code>docs/legal/state-bar-scope-statement.md</code>                                                                             |

## Tests that prove the legal scope holds

| Test                                                                                                                                                                                                 | Verifies                              |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|
| <code>tests/integrations/scope.test.ts</code> — Salesforce <code>defaultpull</code> excludes <code>accountname</code> , <code>opportunity_name</code>                                                | Customer-of-customer data exclusion   |
| <code>tests/integrations/scope.test.ts</code> — Slack <code>defaultpull</code> and <code>optin_pull</code> both exclude any <code>*_text</code> , <code>*_body</code> , <code>*_content</code> field | Slack content exclusion (TOS + risk)  |
| <code>tests/integrations/scope.test.ts</code> — Calendar <code>defaultpull</code> excludes <code>meetingtitle</code> ; <code>optinpull</code> may include it                                         | Title exclusion at default tier       |
| <code>tests/integrations/scope.test.ts</code> — every <code>default_pull</code> field maps to a real competency                                                                                      | Data-minimization (no orphan pulls)   |
| <code>tests/integrations/scope.test.ts</code> — <code>neverpull</code> and <code>defaultpull</code> have no overlap                                                                                  | Tier integrity                        |
| <code>tests/integrations/scope.test.ts</code> — <code>neverpull</code> and <code>optin_pull</code> have no overlap                                                                                   | Hard limits cannot be opted into      |
| <code>tests/integrations/scope.test.ts</code> — every integration declares <code>subprocessor</code> + <code>euresidency</code>                                                                      | Sub-processor list completeness       |
| <code>tests/parsers/special-category.test.ts</code> — workbook column "race" rejected                                                                                                                | Art. 9 enforcement (Plan 2 carryover) |

| Test                                                                                                                                        | Verifies                           |
|---------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------|
| End-to-end<br><code>tests/integrations/consent-screen.test.ts</code><br>— OAuth consent screen renders all three tiers from config          | Transparent-notice requirement     |
| End-to-end<br><code>tests/integrations/excluded.test.ts</code> —<br>employee with <code>excluded_from_review=1</code> produces zero signals | Partner-data exclusion (State Bar) |

## Items deferred

- Tokenization layer for LLM prompts — Month 3 (Plan 2)
- Customer-managed encryption keys per integration — Year 1
- Customer-narrowable per-tenant scope overrides — post-pilot (decision #10)
- Workday Partner program — when first enterprise customer demands Workday
- Per-integration KMS keys — Year 1